

WEB APPLICATION SECURITY ASSESSMENT REPORT

Vulnerability Assessment and Penetration Testing (VAPT)

Target Application

Zero Bank Web Application

Target URL

<http://zero.webappsecurity.com>

Assessment Methodology

OWASP Top 10 (2021)

Assessment Type

Black-Box Web Application Security Assessment

Prepared By

Akash Kakad

June 2026

Contents

1	Engagement Overview	1
1.1	Objective	1
1.2	Assessment Goals	1
1.3	Testing Approach	1
2	Executive Summary	2
3	Scope of Assessment	3
3.1	Target Application	3
3.2	Target URL	3
3.3	In-Scope Components	3
3.4	Out-of-Scope Components	3
4	Assessment Methodology	4
4.1	Phase 1: Reconnaissance	4
4.2	Phase 2: Application Mapping	4
5	Security Assessment Workflow	5
6	Reconnaissance and Technology Profiling	6
6.1	Objective	6
6.2	Nmap Enumeration	6
6.2.1	Key Observations	7
6.3	Directory Discovery	7
6.3.1	Key Observations	8
6.4	Technology Fingerprinting	8
7	Vulnerability Summary	9
7.1	Severity Distribution	9
8	Risk Assessment Dashboard	10
8.1	Executive Risk Overview	10

8.2	Risk Metrics	10
8.3	Business Impact Summary	10
9	Finding 1: Username Enumeration Through Authentication Responses	11
9.1	Severity	11
9.2	CVSS Score	11
9.3	OWASP Mapping	11
9.4	Description	11
9.5	Business Impact	11
9.6	Evidence	12
9.7	Risk Assessment	13
9.8	Remediation	13
10	Finding 2: Missing Rate Limiting and Account Lockout Controls	14
10.1	Severity	14
10.2	CVSS Score	14
10.3	OWASP Mapping	14
10.4	Description	14
10.5	Business Impact	15
10.6	Evidence	15
10.7	Risk Assessment	16
10.8	Remediation	16
11	Finding 3: Weak Session Cookie Configuration	17
11.1	Severity	17
11.2	CVSS Score	17
11.3	OWASP Mapping	17
11.4	Description	17
11.5	Business Impact	18
11.6	Evidence	18
11.7	Risk Assessment	19
11.8	Remediation	19
12	Finding 4: Missing HTTP Security Headers	20
12.1	Severity	20
12.2	CVSS Score	20
12.3	OWASP Mapping	20
12.4	Description	20
12.5	Business Impact	21
12.6	Evidence	21

12.7 Risk Assessment	22
12.8 Remediation	22
13 Finding 5: SSL/TLS Security Weaknesses	23
13.1 Severity	23
13.2 CVSS Score	23
13.3 OWASP Mapping	23
13.4 Description	23
13.5 Business Impact	24
13.6 Evidence	24
13.7 Risk Assessment	27
13.8 Remediation	28
14 Security Tool Analysis	29
15 Security Recommendations	30
15.1 Priority 1 - Immediate Actions	30
15.1.1 Authentication Security	30
15.1.2 Session Security	30
15.2 Priority 2 - Security Hardening	30
15.2.1 HTTP Security Headers	30
15.2.2 SSL/TLS Security	31
15.3 Priority 3 - Continuous Improvement	31
16 Remediation Verification	32
17 Conclusion	33
17.1 Lessons Learned	33
18 Skills Demonstrated During Assessment	35
18.1 Technical Skills	35
18.2 Tools Utilized	35
18.3 Frameworks and Standards	36
19 References	37
20 Appendices	38
20.1 Assessment Evidence Index	38
20.2 Assessment Summary	39

List of Figures

5.1	Security Assessment Workflow	5
6.1	Nmap Service Enumeration Results	7
6.2	DirBuster Content Discovery Results	8
9.1	Authentication Response for Non-Existent Username	12
9.2	Authentication Response for Valid Username with Incorrect Password . .	13
10.1	Postman Authentication Testing	15
10.2	Burp Suite Authentication Request Validation	16
11.1	Session Cookie Analysis	18
11.2	Missing Secure and HttpOnly Flags	19
12.1	OWASP ZAP Security Header Findings	21
12.2	Nikto Security Configuration Assessment	22
13.1	Qualys SSL Labs Assessment	24
13.2	SSL Certificate Analysis	25
13.3	Supported Cipher Suite Analysis	26
13.4	SSLScan Results	27

List of Tables

6.1	Technology Stack Overview	8
7.1	Security Findings Summary	9
7.2	Severity Breakdown	9
8.1	Assessment Metrics	10
9.1	Username Enumeration Risk Analysis	13
10.1	Rate Limiting Risk Analysis	16
11.1	Session Cookie Risk Analysis	19
12.1	Security Header Risk Analysis	22
13.1	SSL/TLS Risk Analysis	27
14.1	Security Tool Utilization	29
16.1	Remediation Verification Matrix	32
20.1	Evidence Mapping	38
20.2	Final Security Assessment Summary	39

Chapter 1

Engagement Overview

1.1 Objective

The primary objective of this assessment was to evaluate the security posture of the Zero Bank web application and identify vulnerabilities that could impact confidentiality, integrity, or availability.

1.2 Assessment Goals

- Evaluate authentication security mechanisms
- Assess session management controls
- Review SSL/TLS implementation
- Analyze HTTP security configurations
- Identify security misconfigurations
- Validate application resilience against common attack vectors

1.3 Testing Approach

A black-box testing methodology was adopted. No source code, backend infrastructure access, or privileged information was provided before testing.

The assessment simulated the perspective of an external attacker attempting to identify weaknesses using publicly accessible application functionality.

Chapter 2

Executive Summary

A comprehensive Vulnerability Assessment and Penetration Testing (VAPT) engagement was conducted against the Zero Bank training web application to evaluate its resilience against common web application attack techniques and security misconfigurations.

The assessment followed a structured methodology aligned with the OWASP Top 10 (2021) framework and focused on authentication security, session management controls, SSL/TLS security posture, server configuration weaknesses, and network communication behavior.

Industry-standard security tools including Burp Suite Professional, OWASP ZAP, Postman, Wireshark, Nmap, Nikto, SSLScan, Qualys SSL Labs, and DirBuster were utilized throughout the engagement.

Five security findings were identified during testing:

- Username Enumeration
- Missing Rate Limiting Controls
- Weak Session Cookie Configuration
- Missing HTTP Security Headers
- SSL/TLS Security Weaknesses

The findings demonstrate common vulnerabilities frequently observed during real-world security assessments and highlight areas where application security controls can be improved.

Overall Risk Rating: **HIGH**

Chapter 3

Scope of Assessment

3.1 Target Application

Zero Bank Web Application

3.2 Target URL

<http://zero.webappsecurity.com>

3.3 In-Scope Components

- Authentication Portal
- Login Workflow
- Session Management
- HTTP Communication
- Application Endpoints

3.4 Out-of-Scope Components

- Source Code Review
- Backend Infrastructure
- Production Databases
- Internal Network Services
- Third-Party Systems

Chapter 4

Assessment Methodology

The assessment followed a structured methodology based on OWASP Web Security Testing principles.

4.1 Phase 1: Reconnaissance

Activities performed:

- Service Enumeration
- Technology Fingerprinting
- Attack Surface Identification
- Content Discovery

Tools:

- Nmap
- DirBuster

4.2 Phase 2: Application Mapping

Activities performed:

- Site Crawling
- Endpoint Discovery

Tools:

- Burp Suite Professional
- OWASP ZAP

Chapter 5

Security Assessment Workflow

The assessment followed a structured Vulnerability Assessment and Penetration Testing (VAPT) lifecycle aligned with OWASP Testing Methodologies and industry-standard penetration testing practices.

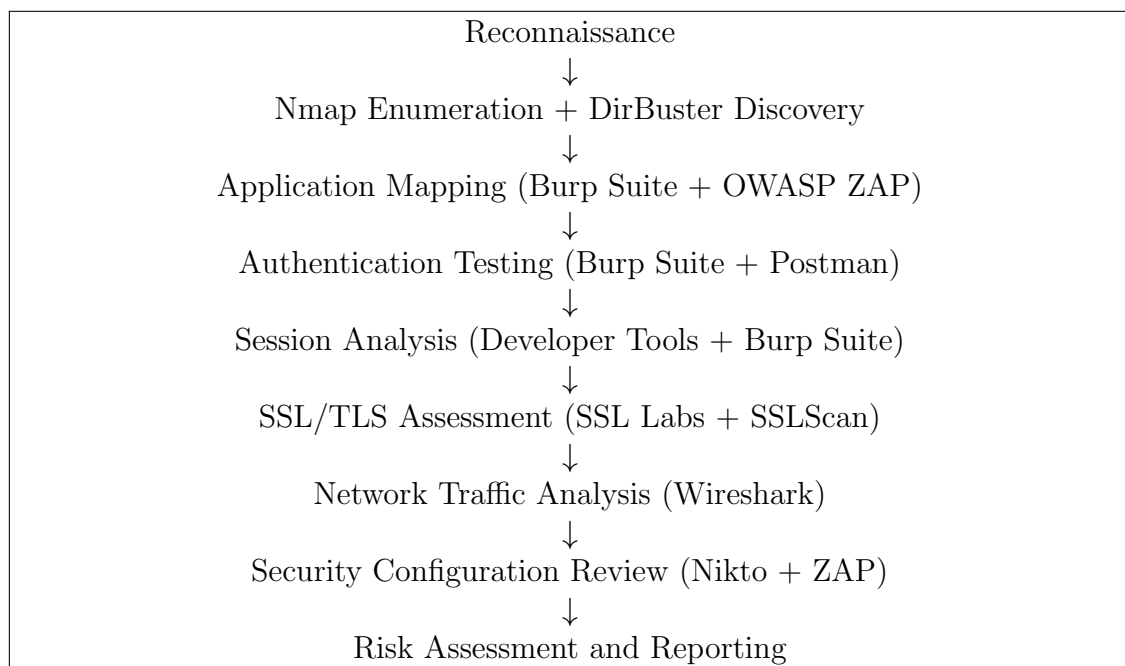


Figure 5.1: Security Assessment Workflow

This methodology ensured comprehensive coverage of authentication security, session management controls, SSL/TLS implementation, application configuration, and network communications.

Chapter 6

Reconnaissance and Technology Profiling

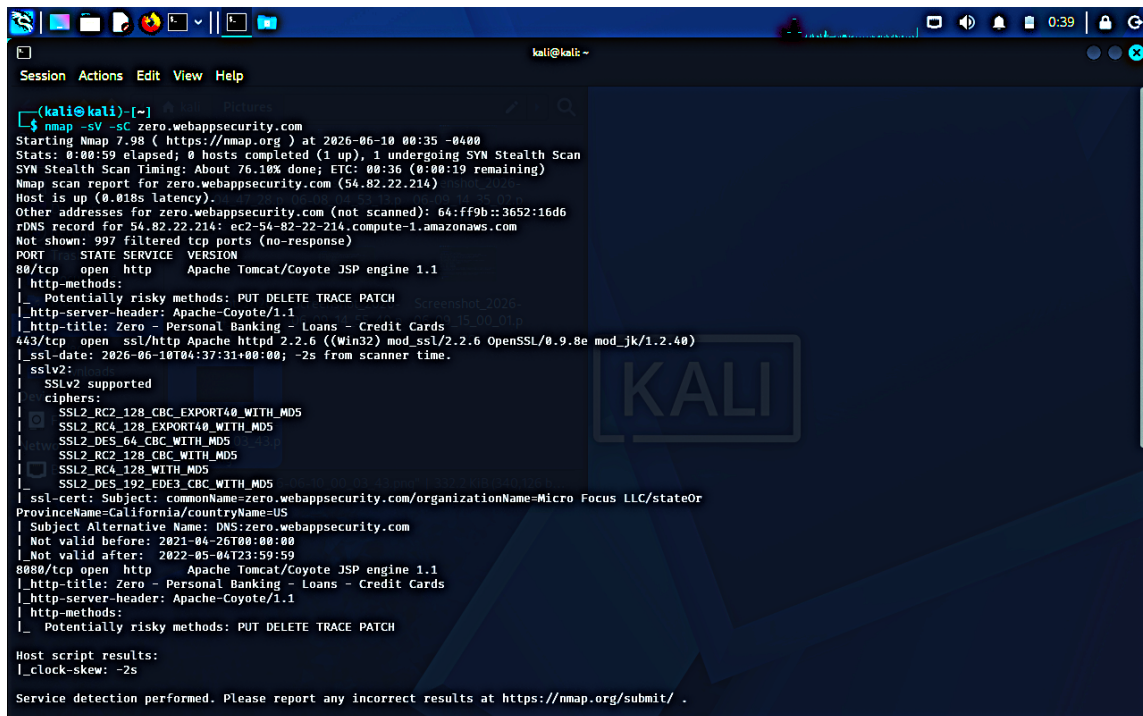
6.1 Objective

The objective of reconnaissance was to identify exposed services, discover hidden resources, enumerate application technologies, and establish an understanding of the application's attack surface before conducting active security testing.

6.2 Nmap Enumeration

Nmap was utilized to identify exposed services, accessible ports, and web server technologies.

The scan revealed the presence of HTTP and HTTPS services exposed by the application.



```
(kali@kali)-[~]
└─$ nmap -sV -sC zero.webappsecurity.com
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-10 00:35 -0400
Stats: 0:00:59 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 76.10% done; ETC: 00:36 (0:00:19 remaining)
Nmap scan report for zero.webappsecurity.com (54.82.22.214)
Host is up (0.018s latency).
Other addresses for zero.webappsecurity.com (not scanned): 64:ff9b::3652:16d6
rDNS record for 54.82.22.214: ec2-54-82-22-214.compute-1.amazonaws.com
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache Tomcat/Coyote JSP engine 1.1
|_ http-methods:
|_   Potentially risky methods: PUT DELETE TRACE PATCH
|_ http-server-header: Apache-Coyote/1.1
|_ http-title: Zero - Personal Banking - Loans - Credit Cards
443/tcp    open  ssl/http  Apache httpd 2.2.6 ((Win32) mod_ssl/2.2.6 OpenSSL/0.9.8e mod_jk/1.2.40)
|_ ssl-date: 2026-06-10T04:37:31+00:00; -2s from scanner time.
|_ sslv2:
|_   SSLv2 supported
|_   ciphers:
|_     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_     SSL2_RC4_128_EXPORT40_WITH_MD5
|_     SSL2_DES_64_CBC_WITH_MD5
|_     SSL2_RC2_128_CBC_WITH_MD5
|_     SSL2_RC4_128_WITH_MD5
|_     SSL2_DES_192_EDE3_CBC_WITH_MD5
|_ ssl-cert: Subject: commonName=zero.webappsecurity.com/organizationName=Micro Focus LLC/stateOrProvinceName=California/countryName=US
|_ Subject Alternative Name: DNS:zero.webappsecurity.com
|_ Not valid before: 2021-04-26T00:00:00
|_ Not valid after: 2022-05-04T23:59:59
8080/tcp   open  http      Apache Tomcat/Coyote JSP engine 1.1
|_ http-title: Zero - Personal Banking - Loans - Credit Cards
|_ http-server-header: Apache-Coyote/1.1
|_ http-methods:
|_   Potentially risky methods: PUT DELETE TRACE PATCH
Host script results:
|_ clock-skew: -2s
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
```

Figure 6.1: Nmap Service Enumeration Results

6.2.1 Key Observations

- Web services were publicly accessible.
- Multiple HTTP-based services were identified.
- Server fingerprinting information was exposed.

6.3 Directory Discovery

DirBuster was utilized to enumerate hidden directories and resources.

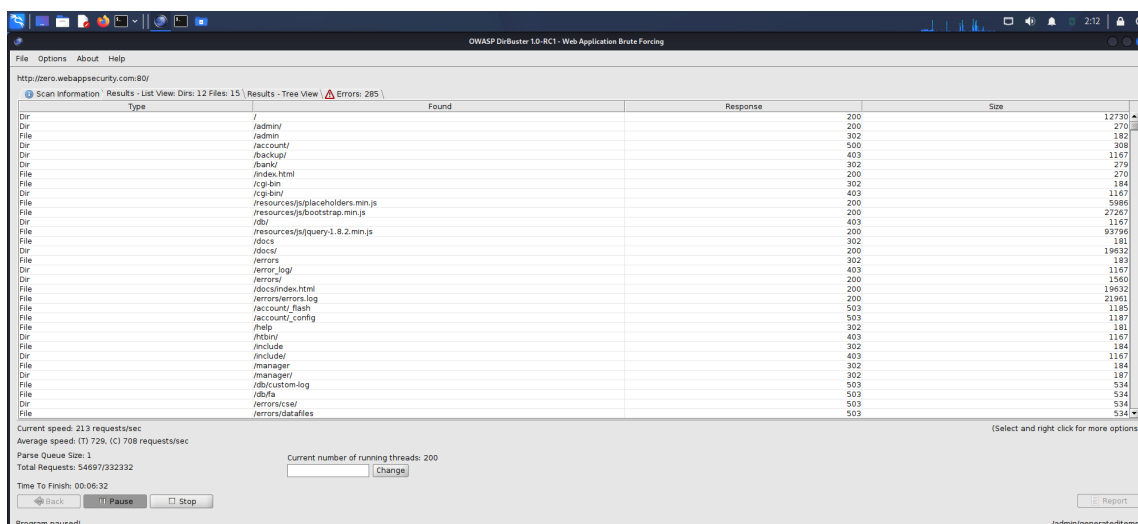


Figure 6.2: DirBuster Content Discovery Results

6.3.1 Key Observations

- Multiple application resources were discoverable.
- Hidden application directories were identified.
- Additional attack surface information became available.

6.4 Technology Fingerprinting

Analysis identified the following technology stack characteristics.

Table 6.1: Technology Stack Overview

Component	Observation
Application Type	Banking Web Application
Architecture	Web-Based Application
Protocol	HTTP/1.1
Session Technology	JSESSIONID Cookies
Server Platform	Apache-Coyote/1.1
Testing Methodology	Black-Box Assessment

Chapter 7

Vulnerability Summary

A total of five security findings were identified during the assessment.

Table 7.1: Security Findings Summary

Finding	OWASP Mapping	Severity
Username Enumeration	A07:2021 Authentication Failures	High
Missing Rate Limiting Controls	A07:2021 Authentication Failures	High
Weak Session Cookie Configuration	A05:2021 Security Misconfiguration	High
Missing HTTP Security Headers	A05:2021 Security Misconfiguration	Medium
SSL/TLS Security Weaknesses	A02:2021 Cryptographic Failures	Medium

7.1 Severity Distribution

Table 7.2: Severity Breakdown

Severity	Count
Critical	0
High	3
Medium	2
Low	0
Informational	0

The assessment indicates weaknesses primarily affecting authentication security, session protection mechanisms, and cryptographic configurations.

Chapter 8

Risk Assessment Dashboard

8.1 Executive Risk Overview

The overall security posture of the target application is assessed as:

8.2 Risk Metrics

Table 8.1: Assessment Metrics

Metric	Value
Assessment Type	Black Box
Methodology	OWASP Top 10 (2021)
Total Findings	5
High Severity Findings	3
Medium Severity Findings	2
Tools Utilized	9
Target Application	Zero Bank

8.3 Business Impact Summary

If exploited by malicious actors, the identified vulnerabilities could result in:

- User Account Enumeration
- Brute Force Authentication Attempts
- Increased Exposure to Client-Side Attacks
- Reduced Cryptographic Assurance

The most significant risks are concentrated within authentication and session management mechanisms.

Chapter 9

Finding 1: Username Enumeration Through Authentication Responses

9.1 Severity

HIGH

9.2 CVSS Score

7.5

9.3 OWASP Mapping

A07:2021 – Identification and Authentication Failures

9.4 Description

During authentication testing, the application returned distinguishable responses based on whether a submitted username existed within the backend user repository.

When invalid usernames were submitted, the application generated a response indicating that the account did not exist. Conversely, when valid usernames were supplied with incorrect passwords, the application returned a different response.

This behavior allows attackers to enumerate valid user accounts through repeated authentication attempts.

9.5 Business Impact

Username enumeration increases the effectiveness of:

- Credential Stuffing Attacks
- Password Spraying Attacks
- Brute Force Campaigns
- Social Engineering Operations

Attackers can focus only on verified accounts, significantly improving attack success rates.

9.6 Evidence

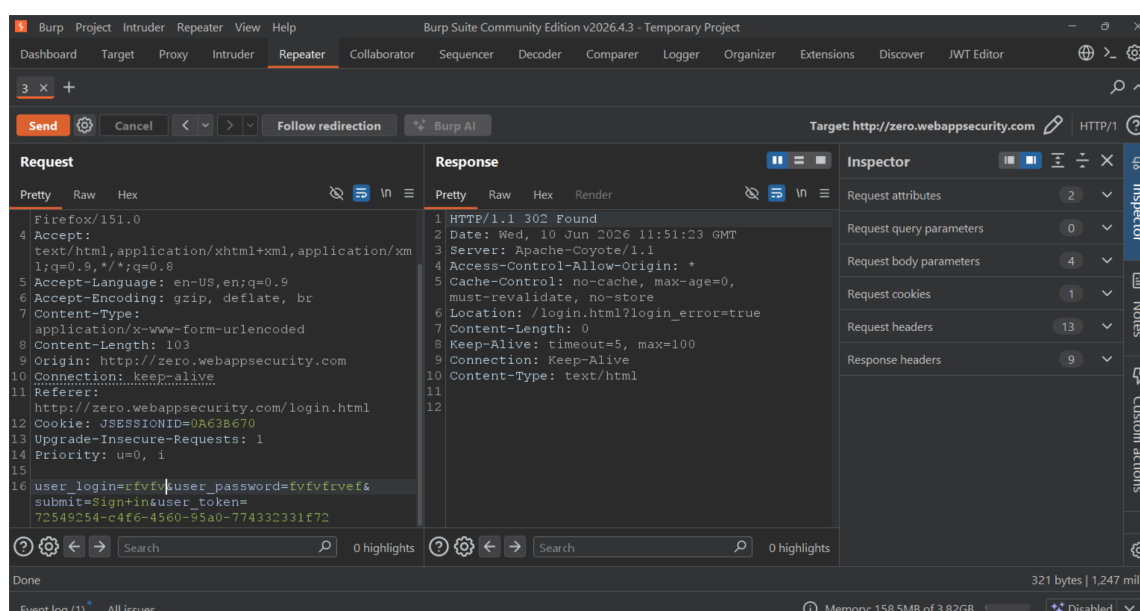


Figure 9.1: Authentication Response for Non-Existent Username

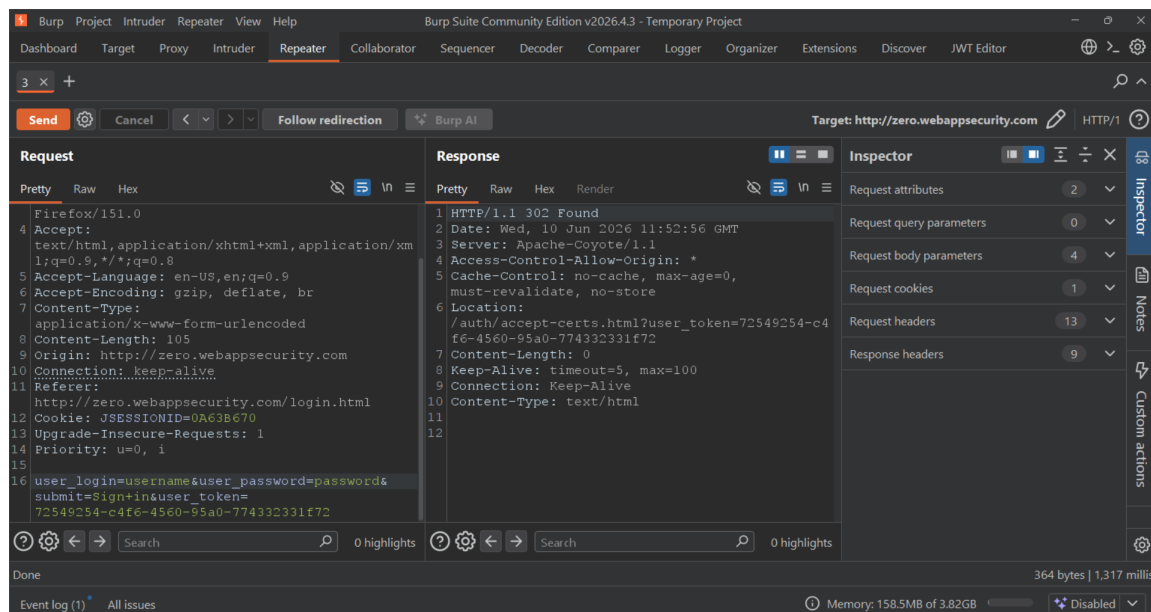


Figure 9.2: Authentication Response for Valid Username with Incorrect Password

9.7 Risk Assessment

Table 9.1: Username Enumeration Risk Analysis

Metric	Value
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Confidentiality Impact	High
Integrity Impact	None
Availability Impact	None

9.8 Remediation

Authentication failures should always return identical responses regardless of account validity.

Recommended implementation:

```
Invalid username or password.
```

Additionally:

- Standardize response length
- Standardize response timing
- Standardize HTTP status codes

Chapter 10

Finding 2: Missing Rate Limiting and Account Lockout Controls

10.1 Severity

HIGH

10.2 CVSS Score

8.1

10.3 OWASP Mapping

A07:2021 – Identification and Authentication Failures

10.4 Description

Testing confirmed the absence of authentication throttling controls.

Multiple consecutive login requests were submitted using automated testing tools without triggering:

- Account Lockouts
- Temporary Delays
- Request Throttling
- CAPTCHA Challenges

This weakness enables automated password guessing attacks and credential stuffing campaigns.

10.5 Business Impact

An attacker could perform:

- Brute Force Attacks
- Credential Stuffing
- Password Spraying
- Automated Account Takeover Attempts

Weak user passwords become highly susceptible to compromise.

10.6 Evidence

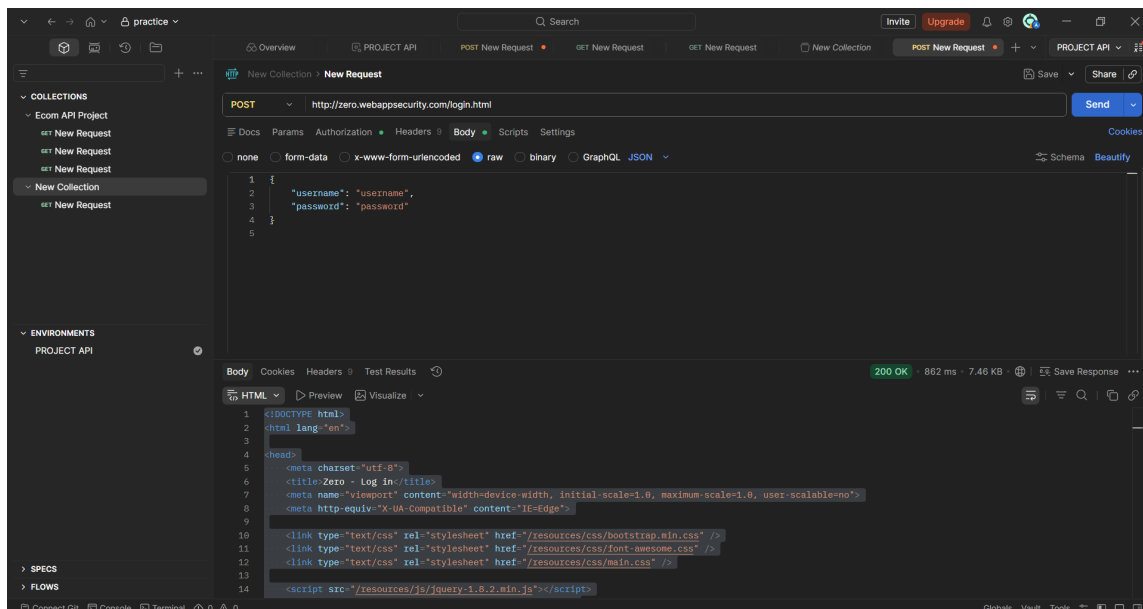


Figure 10.1: Postman Authentication Testing

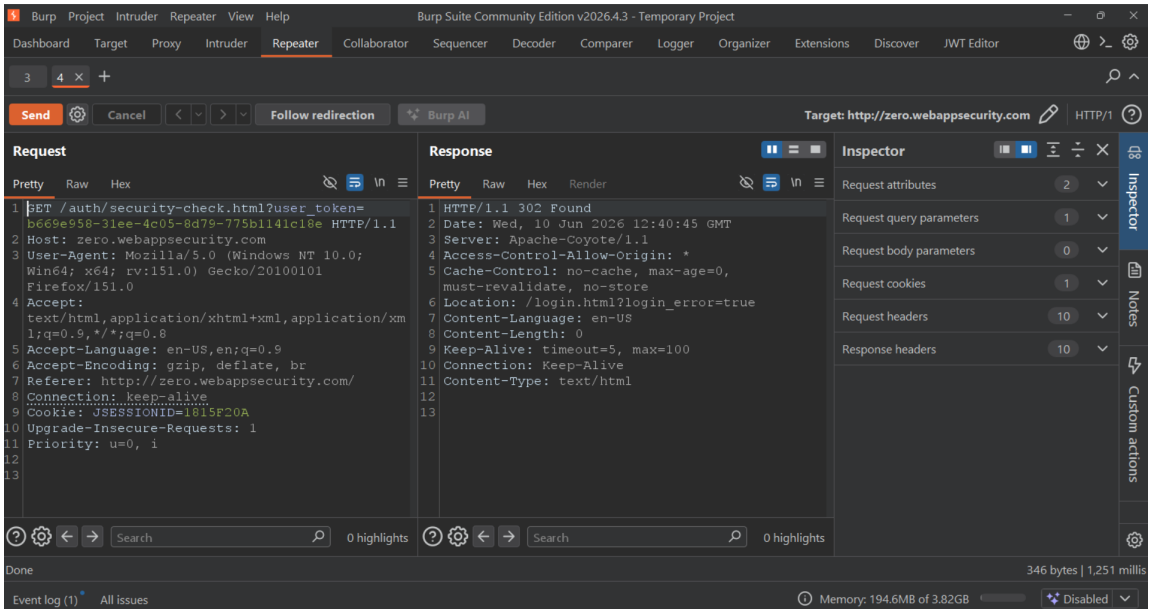


Figure 10.2: Burp Suite Authentication Request Validation

10.7 Risk Assessment

Table 10.1: Rate Limiting Risk Analysis

Metric	Value
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Confidentiality Impact	High
Integrity Impact	High
Availability Impact	Low

10.8 Remediation

Implement authentication protection mechanisms including:

- Account Lockout Policies
- Progressive Authentication Delays
- CAPTCHA Validation
- Maximum Failed Attempts: 5
- Lockout Duration: 15 Minutes
- Alert Threshold: 10 Failed Attempts

Chapter 11

Finding 3: Weak Session Cookie Configuration

11.1 Severity

HIGH

11.2 CVSS Score

8.0

11.3 OWASP Mapping

A05:2021 – Security Misconfiguration

11.4 Description

Session cookie analysis identified missing security attributes within authentication tokens.

The following cookie protections were absent:

- HttpOnly
- Secure

Without these protections, session tokens may be exposed to client-side attacks and interception risks.

11.5 Business Impact

Successful compromise of session identifiers may allow attackers to:

- Hijack Authenticated Sessions
- Impersonate Legitimate Users
- Access Sensitive Information
- Conduct Unauthorized Actions

11.6 Evidence

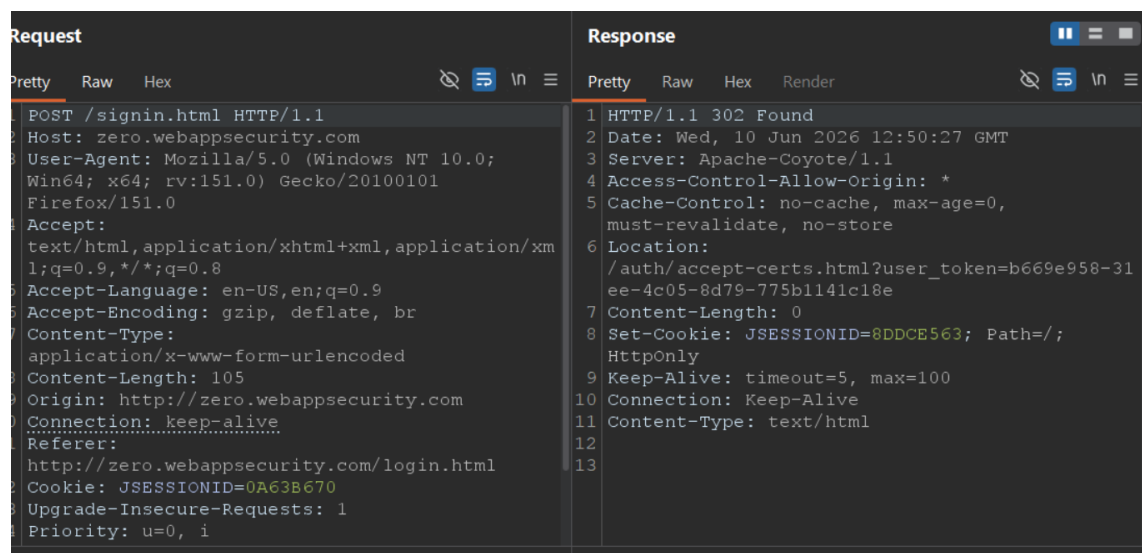


Figure 11.1: Session Cookie Analysis

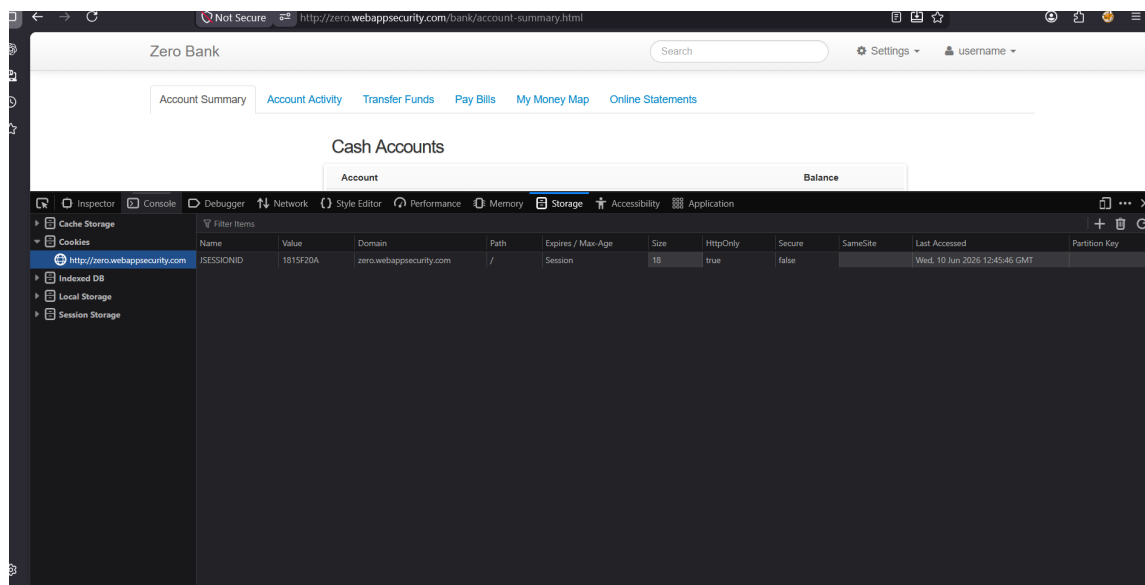


Figure 11.2: Missing Secure and HttpOnly Flags

11.7 Risk Assessment

Table 11.1: Session Cookie Risk Analysis

Metric	Value
Attack Complexity	Low
Privileges Required	None
User Interaction	Required
Confidentiality Impact	High
Integrity Impact	High
Availability Impact	None

11.8 Remediation

All session cookies should enforce secure attributes.

Recommended configuration:

```
Set-Cookie:
JSESSIONID=<token>;
Secure;
HttpOnly;
SameSite=Strict
```

- Regenerate Sessions After Login
- Implement Session Expiration Controls
- Enable SameSite Protections

Chapter 12

Finding 4: Missing HTTP Security Headers

12.1 Severity

MEDIUM

12.2 CVSS Score

5.3

12.3 OWASP Mapping

A05:2021 – Security Misconfiguration

12.4 Description

Security header analysis performed using OWASP ZAP and Nikto revealed that multiple critical HTTP response headers were absent from application responses.

The missing headers included:

- Content-Security-Policy (CSP)
- X-Frame-Options
- X-Content-Type-Options
- Referrer-Policy

Security headers provide an additional defensive layer against browser-based attacks and content injection techniques.

12.5 Business Impact

The absence of security headers may expose users to:

- Clickjacking Attacks
- Cross-Site Scripting (XSS)
- MIME-Type Confusion Attacks
- Content Injection Attacks

These weaknesses increase client-side attack exposure and reduce browser-enforced security controls.

12.6 Evidence

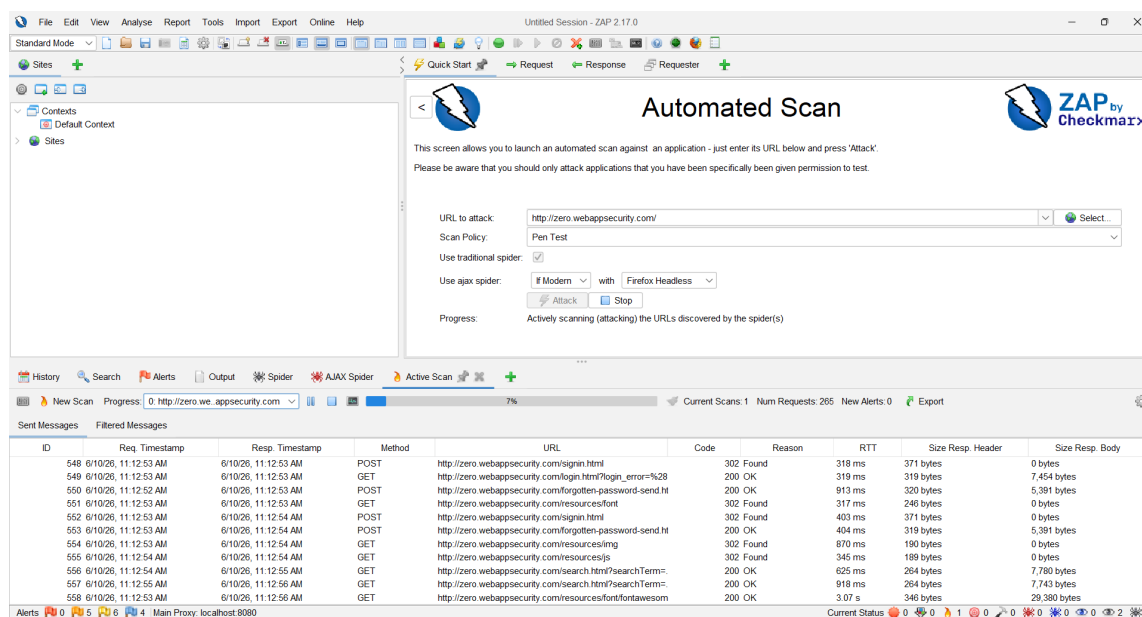
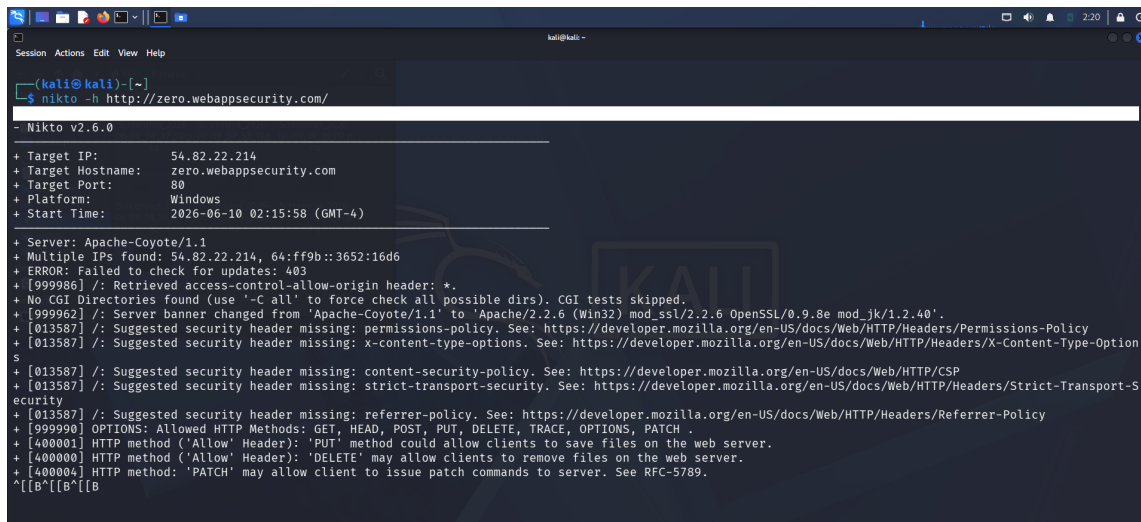


Figure 12.1: OWASP ZAP Security Header Findings



```

kali@kali:~$ nikto -h http://zero.webappsecurity.com/
- Nikto v2.6.0

+ Target IP: 54.82.22.214
+ Target Hostname: zero.webappsecurity.com
+ Target Port: 80
+ Platform: Windows
+ Start Time: 2026-06-10 02:15:58 (GMT-4)

+ Server: Apache-Coyote/1.1
+ Multiple IPs found: 54.82.22.214, 64:ff9b::3652:16d6
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved access-control-allow-origin header: *.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999962] /: Server banner changed from 'Apache-Coyote/1.1' to 'Apache/2.2.6 (Win32) mod_ssl/2.2.6 OpenSSL/0.9.8e mod_jk/1.2.40'.
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [999990] OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, PUT, DELETE, TRACE, OPTIONS, PATCH .
+ [4000001] HTTP method ('Allow' Header): 'PUT' method could allow clients to save files on the web server.
+ [4000000] HTTP method ('Allow' Header): 'DELETE' may allow clients to remove files on the web server.
+ [4000004] HTTP method: 'PATCH' may allow client to issue patch commands to server. See RFC-5789.
^[[B^[[B^[[B

```

Figure 12.2: Nikto Security Configuration Assessment

12.7 Risk Assessment

Table 12.1: Security Header Risk Analysis

Metric	Value
Attack Complexity	Low
Privileges Required	None
User Interaction	Required
Confidentiality Impact	Medium
Integrity Impact	Medium
Availability Impact	None

12.8 Remediation

Implement the following response headers:

```

Content-Security-Policy: default-src 'self';
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: geolocation=()

```

Regular security header validation should be integrated into the application deployment lifecycle.

Chapter 13

Finding 5: SSL/TLS Security Weaknesses

13.1 Severity

MEDIUM

13.2 CVSS Score

6.4

13.3 OWASP Mapping

A02:2021 – Cryptographic Failures

13.4 Description

SSL/TLS testing identified weaknesses within the application's cryptographic configuration.

Assessment activities included:

- SSL Labs Assessment
- SSLScan Enumeration
- Certificate Validation
- Cipher Suite Analysis

The assessment revealed weak cryptographic configurations and certificate-related concerns affecting transport security.

13.5 Business Impact

Weak SSL/TLS configurations may increase exposure to:

- Man-in-the-Middle Attacks
- Traffic Interception
- Protocol Downgrade Attacks
- Cryptographic Exploitation

These weaknesses reduce confidence in secure communications between users and the application.

13.6 Evidence

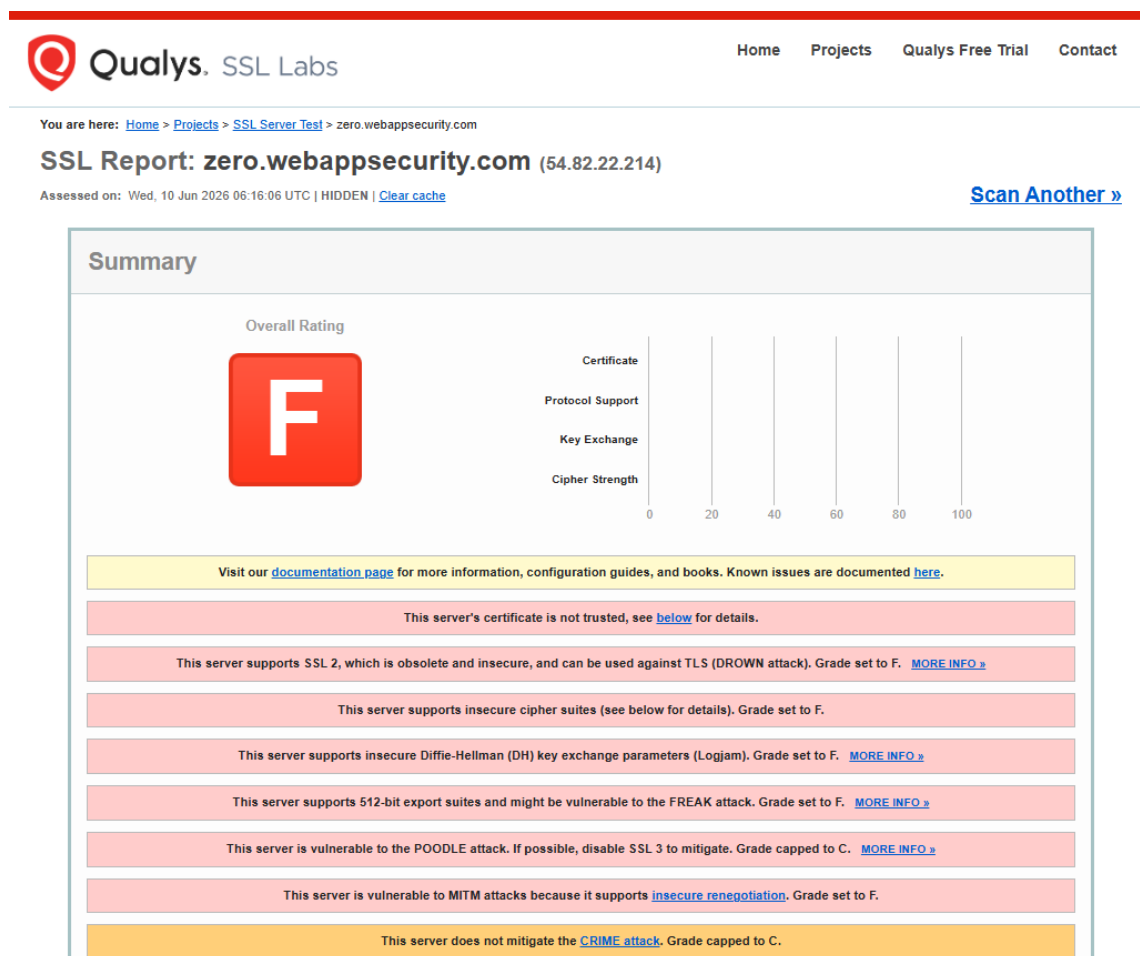


Figure 13.1: Qualys SSL Labs Assessment

Certificate #1: RSA 2048 bits (SHA256withRSA)



Server Key and Certificate #1

Subject	zero.webappsecurity.com Fingerprint SHA256: b02a9cda23385967200ce500fa915a0920b4883eb89a81f015b8c312bb93cfd Pin SHA256: iTZeCJz9Qajir55NuPqDUfs2PN5Py8m8blg7cUxAO2k=
Common names	zero.webappsecurity.com
Alternative names	zero.webappsecurity.com
Serial Number	04b63f6f4401bac5f089ec7afc0a5287
Valid from	Mon, 26 Apr 2021 00:00:00 UTC
Valid until	Wed, 04 May 2022 23:59:59 UTC (expired 4 years and 1 month ago) EXPIRED
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	DigiCert TLS RSA SHA256 2020 CA 1 AIA: http://ca.certs.digicert.com/DigiCertTLRSASHA2562020CA1.crt
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	CRL: http://crl3.digicert.com/DigiCertTLRSASHA2562020CA1.crl OCSP: http://ocsp.digicert.com
Revocation status	Unchecked (only trusted certificates can be checked)
DNS CAA	No (more info)
Trusted	No NOT TRUSTED (Why?) Mozilla Apple Android Java Windows



Additional Certificates (if supplied)

Certificates provided	2 (2996 bytes)
Chain issues	None

#2

DigiCert TLS RSA SHA256 2020 CA 1

Figure 13.2: SSL Certificate Analysis

 Cipher Suites	
# TLS 1.0 (server has no preference) 	
TLS_RSA_EXPORT_WITH_RC4_40_MD5 (0x3) INSECURE	40
TLS_RSA_EXPORT_WITH_RC2_CBC_40_MD5 (0x6) INSECURE	40
TLS_RSA_EXPORT_WITH_DES40_CBC_SHA (0x8) INSECURE	40
TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA (0x14) DH 512 bits FS INSECURE	40
TLS_RSA_WITH_DES_CBC_SHA (0x9) INSECURE	56
TLS_DHE_RSA_WITH_DES_CBC_SHA (0x15) DH 1024 bits FS INSECURE	56
TLS_RSA_WITH_3DES_EDE_CBC_SHA (0xa) WEAK	112
TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA (0x16) DH 1024 bits FS WEAK	112
TLS_RSA_WITH_AES_128_CBC_SHA (0x2f) WEAK	128
TLS_DHE_RSA_WITH_AES_128_CBC_SHA (0x33) DH 1024 bits FS WEAK	128
TLS_RSA_WITH_RC4_128_MD5 (0x4) INSECURE	128
TLS_RSA_WITH_RC4_128_SHA (0x5) INSECURE	128
TLS_RSA_WITH_AES_256_CBC_SHA (0x35) WEAK	256
TLS_DHE_RSA_WITH_AES_256_CBC_SHA (0x39) DH 1024 bits FS WEAK	256
# SSL 3 (server has no preference) 	
TLS_RSA_EXPORT_WITH_RC4_40_MD5 (0x3) INSECURE	40
TLS_RSA_EXPORT_WITH_RC2_CBC_40_MD5 (0x6) INSECURE	40
TLS_RSA_EXPORT_WITH_DES40_CBC_SHA (0x8) INSECURE	40
TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA (0x14) DH 512 bits FS INSECURE	40
TLS_RSA_WITH_DES_CBC_SHA (0x9) INSECURE	56
TLS_DHE_RSA_WITH_DES_CBC_SHA (0x15) DH 1024 bits FS INSECURE	56
TLS_RSA_WITH_3DES_EDE_CBC_SHA (0xa) WEAK	112
TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA (0x16) DH 1024 bits FS WEAK	112
TLS_RSA_WITH_AES_128_CBC_SHA (0x2f) WEAK	128
TLS_DHE_RSA_WITH_AES_128_CBC_SHA (0x33) DH 1024 bits FS WEAK	128
TLS_RSA_WITH_RC4_128_MD5 (0x4) INSECURE	128
TLS_RSA_WITH_RC4_128_SHA (0x5) INSECURE	128
TLS_RSA_WITH_AES_256_CBC_SHA (0x35) WEAK	256
TLS_DHE_RSA_WITH_AES_256_CBC_SHA (0x39) DH 1024 bits FS WEAK	256

Figure 13.3: Supported Cipher Suite Analysis


```

Session Actions Edit View Help
Nmap done: 1 IP address (1 host up) scanned in 139.56 seconds
(kali@kali)-[~]
$ sslscan zero.webappsecurity.com
Version: 2.1.5
OpenSSL 3.5.5 27 Jan 2026
Connected to 54.82.22.214
Testing SSL server zero.webappsecurity.com on port 443 using SNI name zero.webappsecurity.com

SSL/TLS Protocols:
SSLv2      enabled
SSLv3      enabled
TLSv1.0    enabled
TLSv1.1    disabled
TLSv1.2    disabled
TLSv1.3    disabled

TLS Fallback SCSV:
Server does not support TLS Fallback SCSV

TLS renegotiation:
Insecure session renegotiation supported

TLS Compression:
Compression enabled (CRIME)

Heartbleed:
TLSv1.0 not vulnerable to heartbleed

Supported Server Cipher(s):
Preferred TLSv1.0 256 bits DHE-RSA-AES256-SHA DHE 1024 bits
Accepted TLSv1.0 128 bits DHE-RSA-AES128-SHA DHE 1024 bits
Accepted TLSv1.0 256 bits AES256-SHA
Accepted TLSv1.0 128 bits AES128-SHA
Accepted TLSv1.0 40 bits TLS_RSA_EXPORT_WITH_RC4_40_MD5
Accepted TLSv1.0 128 bits TLS_RSA_WITH_RC4_128_MD5
Accepted TLSv1.0 128 bits TLS_RSA_WITH_RC4_128_SHA
Accepted TLSv1.0 40 bits TLS_RSA_EXPORT_WITH_RC2_CBC_40_MD5
Accepted TLSv1.0 40 bits TLS_RSA_EXPORT_WITH_DES40_CBC_SHA
Accepted TLSv1.0 56 bits TLS_RSA_WITH_DES_CBC_SHA
Accepted TLSv1.0 112 bits TLS_RSA_WITH_3DES_EDE_CBC_SHA
Accepted TLSv1.0 40 bits TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA
Accepted TLSv1.0 56 bits TLS_DHE_RSA_WITH_DES_CBC_SHA
Accepted TLSv1.0 112 bits TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA

SSL Certificate:
Signature Algorithm: sha256WithRSAEncryption
RSA Key Strength: 2048

Subject: zero.webappsecurity.com
AltNames: DNS:zero.webappsecurity.com
Issuer: DigiCert TLS RSA SHA256 2020 CA1

Not valid before: Apr 26 00:00:00 2021 GMT
Not valid after: May 4 23:59:59 2022 GMT

```

Figure 13.4: SSLScan Results

13.7 Risk Assessment

Table 13.1: SSL/TLS Risk Analysis

Metric	Value
Attack Complexity	Medium
Privileges Required	None
User Interaction	Required
Confidentiality Impact	High
Integrity Impact	Medium
Availability Impact	None

13.8 Remediation

Recommended hardening measures:

- Disable SSLv2 and SSLv3
- Disable TLS 1.0 and TLS 1.1
- Enable TLS 1.2 and TLS 1.3
- Remove weak ciphers
- Use trusted certificates
- Implement certificate lifecycle monitoring

Chapter 14

Security Tool Analysis

The following tools were utilized throughout the assessment.

Table 14.1: Security Tool Utilization

Tool	Purpose	Outcome
Nmap	Service Enumeration	Attack Surface Discovery
DirBuster	Content Discovery	Hidden Resource Enumeration
Burp Suite Professional	Manual Security Testing	Authentication Analysis
OWASP ZAP	Automated Scanning	Security Misconfiguration Detection
Postman	API Testing	Authentication Workflow Validation
Wireshark	Traffic Analysis	Packet Inspection
Nikto	Server Security Review	Configuration Assessment
SSLScan	TLS Enumeration	Cipher Validation
Qualys SSL Labs	SSL Assessment	Cryptographic Posture Review

The combination of automated and manual testing techniques provided comprehensive visibility into the application's security posture.

Chapter 15

Security Recommendations

The following remediation actions are recommended based on the findings identified during the assessment.

15.1 Priority 1 - Immediate Actions

15.1.1 Authentication Security

- Standardize authentication responses
- Implement account lockout controls
- Introduce rate limiting mechanisms
- Enable CAPTCHA after repeated failures

15.1.2 Session Security

- Enable Secure cookies
- Enable HttpOnly cookies
- Implement SameSite protections
- Regenerate sessions after authentication

15.2 Priority 2 - Security Hardening

15.2.1 HTTP Security Headers

Implement:

```
Content-Security-Policy
X-Frame-Options
X-Content-Type-Options
Referrer-Policy
Permissions-Policy
```

15.2.2 SSL/TLS Security

- Disable legacy protocols
- Remove weak ciphers
- Use strong certificates
- Perform periodic SSL reviews

15.3 Priority 3 - Continuous Improvement

- Quarterly Vulnerability Assessments
- Annual Penetration Testing
- Security Awareness Training
- Continuous Monitoring
- Log Review and Alerting

Chapter 16

Remediation Verification

This section describes how each identified vulnerability should be validated following implementation of corrective actions.

Table 16.1: Remediation Verification Matrix

Finding	Recommended Fix	Verification Method
Username Enumeration	Standardize Authentication Responses	Test valid and invalid usernames and verify identical responses
Missing Rate Limiting	Implement Authentication Throttling	Submit repeated login attempts and verify account lockout or HTTP 429 responses
Weak Cookie Configuration	Enable Secure and HttpOnly Flags	Inspect cookies in browser developer tools and verify security attributes
Missing Security Headers	Configure Secure HTTP Headers	Verify presence of CSP, X-Frame-Options and related headers
SSL/TLS Weaknesses	Harden TLS Configuration	Re-run SSL Labs and SSLScan assessments and confirm improved ratings

Successful remediation should be independently validated through follow-up testing before deployment into production environments.

Chapter 17

Conclusion

A comprehensive Vulnerability Assessment and Penetration Testing (VAPT) engagement was successfully conducted against the Zero Bank training web application.

The assessment evaluated authentication workflows, session management mechanisms, SSL/TLS configurations, network communications, and application security controls using both automated and manual testing methodologies.

A total of five vulnerabilities were identified:

- Username Enumeration
- Missing Rate Limiting Controls
- Weak Session Cookie Configuration
- Missing HTTP Security Headers
- SSL/TLS Security Weaknesses

Three findings were classified as High Risk and two findings were classified as Medium Risk.

The most significant weaknesses were concentrated within authentication and session management controls. These weaknesses could facilitate credential attacks, session hijacking, and unauthorized access attempts if exploited by malicious actors.

Implementation of the recommendations outlined within this report would significantly improve the application's security posture and reduce exposure to common web-based attack vectors.

17.1 Lessons Learned

This assessment demonstrated the importance of secure authentication design, robust session management, and defense-in-depth security controls.

The engagement highlighted how seemingly small misconfigurations, such as missing security headers or inconsistent authentication responses, can contribute to larger security risks.

The assessment also reinforced the importance of secure SSL/TLS implementations and continuous security validation throughout the software development lifecycle.

Chapter 18

Skills Demonstrated During Assessment

The assessment required the application of multiple offensive and defensive security concepts commonly used in professional penetration testing engagements.

18.1 Technical Skills

- Web Application Penetration Testing
- Vulnerability Assessment
- Authentication Security Testing
- Session Management Analysis
- SSL/TLS Security Assessment
- Network Traffic Analysis
- Security Misconfiguration Detection
- Risk Assessment
- Security Reporting

18.2 Tools Utilized

- Burp Suite Professional
- OWASP ZAP
- Postman

- Wireshark
- Nmap
- DirBuster
- Nikto
- SSLScan
- Qualys SSL Labs

18.3 Frameworks and Standards

- OWASP Top 10 (2021)
- OWASP Testing Guide
- CVSS v3.1
- MITRE CWE
- Security Best Practices

This project demonstrates practical exposure to industry-standard security testing methodologies and tools commonly used by penetration testers, security consultants, and application security professionals.

Chapter 19

References

1. OWASP Foundation. OWASP Top 10 - 2021. Available at: <https://owasp.org/www-project-top-ten/>
2. OWASP Web Security Testing Guide. Available at: <https://owasp.org/www-project-web-security-testing-guide/>
3. OWASP Cheat Sheet Series. Available at: <https://cheatsheetseries.owasp.org/>
4. Common Vulnerability Scoring System (CVSS v3.1). Available at: <https://www.first.org/cvss/>
5. Nmap Network Security Scanner. Available at: <https://nmap.org/>
6. Burp Suite Professional Documentation. Available at: <https://portswigger.net/burp>
7. OWASP ZAP Documentation. Available at: <https://www.zaproxy.org/>
8. Wireshark Documentation. Available at: <https://www.wireshark.org/docs/>
9. Nikto Web Server Scanner. Available at: <https://github.com/sullo/nikto>
10. SSLScan Documentation. Available at: <https://github.com/rbsec/sslscan>
11. Qualys SSL Labs SSL Server Test. Available at: <https://www.ssllabs.com/ssltest/>

Chapter 20

Appendices

20.1 Assessment Evidence Index

The following screenshots were collected throughout the engagement and serve as supporting evidence for assessment activities and findings.

Table 20.1: Evidence Mapping

Figure	Description	Related Section
Figure 1	OWASP ZAP Automated Scan	Methodology
Figure 2	OWASP ZAP Alerts	Finding 4
Figure 3	SSL Labs Assessment	Finding 5
Figure 4	SSL Certificate Analysis	Finding 5
Figure 5	Cipher Suite Review	Finding 5
Figure 6	Wireshark Packet Capture	Network Analysis
Figure 7	Wireshark HTTP Stream	Network Analysis
Figure 8	Postman Authentication Testing	Finding 2
Figure 9	Burp Suite Authentication Testing	Finding 2
Figure 10	Nmap Enumeration	Reconnaissance
Figure 11	SSLScan Results	Finding 5
Figure 12	DirBuster Discovery	Reconnaissance
Figure 13	Nikto Assessment	Finding 4

20.2 Assessment Summary

Table 20.2: Final Security Assessment Summary

Target Application	Zero Bank
Assessment Type	Web Application VAPT
Methodology	OWASP Top 10 (2021)
Assessment Approach	Black Box Testing
Total Findings	5
High Risk Findings	3
Medium Risk Findings	2
Critical Findings	0
Overall Risk Rating	HIGH